Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

Risk Analysis, vol. 38, n.º 2, 2018 DOI: 10.1111/risa.12844

Gestión del riesgo cibernético para infraestructuras críticas: un modelo de análisis de riesgos y tres estudios de caso

M.-Elisabeth Pate´-Cornell,[*] Marshall Kuypers, Matthew Smith y Philip Keller

La gestión de la ciberseguridad en una organización implica distribuir el presupuesto destinado a la protección entre una amplia gama de opciones posibles. Esto requiere evaluar los beneficios y los costes de dichas opciones. Los análisis de riesgos que aquí se presentan son de carácter estadístico cuando se dispone de datos pertinentes, y se basan en el sistema en el caso de incidentes de graves consecuencias que aún no se han producido. Este artículo presenta, en primer lugar, un marco general de análisis probabilístico de riesgos para la ciberseguridad en una organización que se especificará. A continuación, describe tres ejemplos de análisis prospectivos motivados por ciberataques recientes. El primero es el análisis estadístico de una base de datos real, ampliado en el extremo superior de la distribución de pérdidas mediante un análisis bayesiano de posibles escenarios de ataque de graves consecuencias que podrían producirse en el futuro. El segundo es un análisis de sistemas de los riesgos cibernéticos para una red eléctrica inteligente y conectada, que muestra que existe un nivel óptimo de conectividad. El tercero es un análisis de decisiones secuenciales para actualizar el software de un sistema de ciberseguridad existente o adoptar uno nuevo con el fin de adelantarse a los adversarios que intentan abrirse paso. Los resultados son distribuciones de pérdidas por ciberataques, con y sin algunas contramedidas consideradas, en apoyo de las decisiones de gestión de riesgos basadas tanto en datos históricos como en incidentes previstos.

PALABRAS CLAVE: Gestión del riesgo cibernético; ciberseguridad; protección de infraestructuras

1. ATAQUES CIBERNÉTICOS: PROBLEMA Y PARTES INTERESADAS

Los repetidos y frecuentes ciberataques de los últimos años han sacudido la confianza del público en la capacidad de los gestores de infraestructuras para proteger sus sistemas. El catastrofismo tiende a dominar el discurso, con comparaciones con el ataque a Pearl Harbor o incluso con un desastre nuclear. Lamentarse no mejorará la situación. Es necesario abordar las siguientes preguntas: ¿qué se debe hacer, en qué orden y a qué coste? El objetivo de este artículo es mostrar cómo el análisis cuantitativo de riesgos puede respaldar estas decisiones dadas las incertidumbres que ello conlleva, por ejemplo, sobre la identidad de los posibles atacantes y la probabilidad y las consecuencias de un ataque exitoso.

Las medidas de protección analizadas en este artículo abordan las diferentes fases de un ciberataque contra organizaciones concretas. Entre ellas se incluyen la autenticación de dos factores (2FA) para reducir los riesgos de intrusión, el software diseñado y actualizado para proteger la información o impedir su filtración, y la optimización del número de conexiones y vulnerabilidades de un sistema. Cada una de estas medidas conlleva costes y beneficios, a menudo inciertos. Algunos de los costes son tangibles, por ejemplo, el de un nuevo software, mientras que otros no lo son, como las molestias para los usuarios. Las evaluaciones de riesgos aquí descritas arrojan un conjunto de curvas de riesgo para un sistema determinado, con y sin las mejoras consideradas. Estos resultados pueden servir entonces de base para un análisis de decisión, lo que permite

Departamento de Ciencias de la Gestión e Ingeniería, Universidad de Stanford, Stanford, CA, EE. UU.
(*) Dirigir la correspondencia a M.-Elisabeth Pate´-Cornell, de Ciencias de la Gestión e Ingeniería, Universidad de Stanford, Universidad de Stanford, Stanford, CA 94305, EE. UU.;mep@stanford.edu .

0272-4332/18/0100-0226 22,00 $/1 © 2017 Sociedad para el Análisis de Riesgos

un responsable de la toma de decisiones a identificar la medida o el conjunto de medidas que maximizará su utilidad esperada.[1]

Los ciberataques pueden afectar —y en algunos casos ya lo han hecho— a diversas formas de infraestructura crítica de EE. UU., incluida la red eléctrica, las operaciones portuarias, el control del tráfico aéreo y varios otros servicios vitales para la economía del país. Un ciberataque a gran escala contra el sistema de posicionamiento global (GPS) tendría consecuencias devastadoras, dado su papel en numerosos sectores como las comunicaciones, las finanzas, la navegación y el transporte.[2] Las partes interesadas incluyen no solo a las organizaciones objetivo, que podrían perder su propiedad intelectual e ingresos, sino también a sus clientes, cuyos servicios podrían verse interrumpidos y cuya información personal y propiedad intelectual podrían ser robadas.

Recientes ataques de gran repercusión han tenido como objetivo varias entidades del Gobierno de los Estados Unidos. Entre ellas se incluyen:

- **El Departamento de Energía (DoE).** El Gobierno de los Estados Unidos informó de que el DoE había sido objeto de 159 ataques informáticos exitosos a lo largo de un periodo de cuatro años.(1) Esto es motivo de gran preocupación, ya que el DoE participa en la gestión del arsenal nuclear estadounidense y de infraestructuras energéticas críticas, y supervisa investigaciones sensibles en los laboratorios nacionales.
- **La Oficina de Gestión de Personal (OPM).** A partir de 2014, se sustrajeron de la OPM millones de registros de personal, incluidos números de la Seguridad Social y huellas dactilares.(2) Se sospecha que estos incidentes están patrocinados por Estados, y los datos sustraídos podrían utilizarse para la recopilación de inteligencia.

Además, industrias y empresas privadas como Target y Sony han sido atacadas con éxito y han sufrido altos costes, tanto para las organizaciones como para sus clientes. La pregunta, por supuesto, es: ¿qué se debe hacer a continuación —además de lamentar un cambio evidente en la naturaleza de la criminalidad y la guerra— teniendo en cuenta los activos en riesgo, la naturaleza de los atacantes y las vulnerabilidades conocidas o potenciales de los sistemas de información? Como de costumbre, el reto consiste en establecer prioridades para evitar la mala asignación y el desperdicio de recursos.

[1] En todas las aplicaciones aquí presentadas, se supone que el responsable de la toma de decisiones es neutral ante el riesgo. Se pueden introducir diferentes actitudes ante el riesgo mediante otras funciones de utilidad.

[2] Cabe señalar que aquí no se tienen en cuenta los costes secundarios de un ciberataque más allá de los límites de la organización objetivo.

2. ENFOQUES ACTUALES DE LA GESTIÓN DEL RIESGO CIBERNÉTICO Y RESPUESTAS INSTITUCIONALES

2.1. Contramedidas

Los esfuerzos del sector privado y del gobierno para gestionar los riesgos de ciberseguridad se han centrado en el desarrollo de software de seguridad, en las mejores prácticas para el diseño y el funcionamiento de los sistemas, y en mejorar la inversión en personal especializado en ciberseguridad. [3,4]Las medidas de ciberseguridad incluyen la instalación de cortafuegos, el cifrado de software, la detección de virus y la compartimentación de sistemas. Cuando se les pregunta qué es lo más sensible y qué medidas son las más eficaces, los directivos del sector tienden a responder: «todo». Sin embargo, las limitaciones de recursos exigen establecer prioridades basadas en la rentabilidad de las medidas de seguridad, en lugar de adoptar ciegamente un enfoque generalizado. En la mayoría de los casos, la necesidad de seguridad debe equilibrarse con la productividad, ya que diversas opciones pueden resultar engorrosas e interferir en el funcionamiento de un sistema y una organización. Por ejemplo, es poco probable que una contraseña generada aleatoriamente de 16 caracteres sea fácil de recordar, aunque haya demostrado su eficacia.

Hasta ahora, los métodos cuantitativos en el ámbito de la ciberseguridad se han abordado de forma fragmentada. Los investigadores han comenzado a desarrollar modelos cuantitativos de gestión de riesgos(5–7), por ejemplo, la Fuerza Aérea de los Estados Unidos ha aplicado el análisis de decisiones y métodos probabilísticos a sus inversiones en el ciberespacio, tanto en capacidades defensivas como ofensivas.(8) Rao *et al.*(9) presentaron un modelo de teoría de juegos de atacante-defensor para una red cibernética de componentes físicos, y analizaron las compensaciones a las que se enfrenta el defensor a la hora de elegir la protección de la red.

2.2. Enfoques institucionales actuales

Muchas iniciativas para gestionar los riesgos cibernéticos se basan en un enfoque de gestión «de arriba abajo», con el objetivo de animar a los diseñadores y operadores de sistemas a adoptar las mejores prácticas, pero a menudo sin tener en cuenta específicamente la estructura del sistema. Por ejemplo, el Departamento de Defensa de los Estados Unidos ordena a sus agencias y servicios que tengan en cuenta la ciberseguridad al diseñar y operar sistemas de control industrial (ICS), pero sin ofrecer mucha orientación sobre cómo hacerlo.(10) Existen varios documentos generales disponibles sobre el tema.(4,11,12)

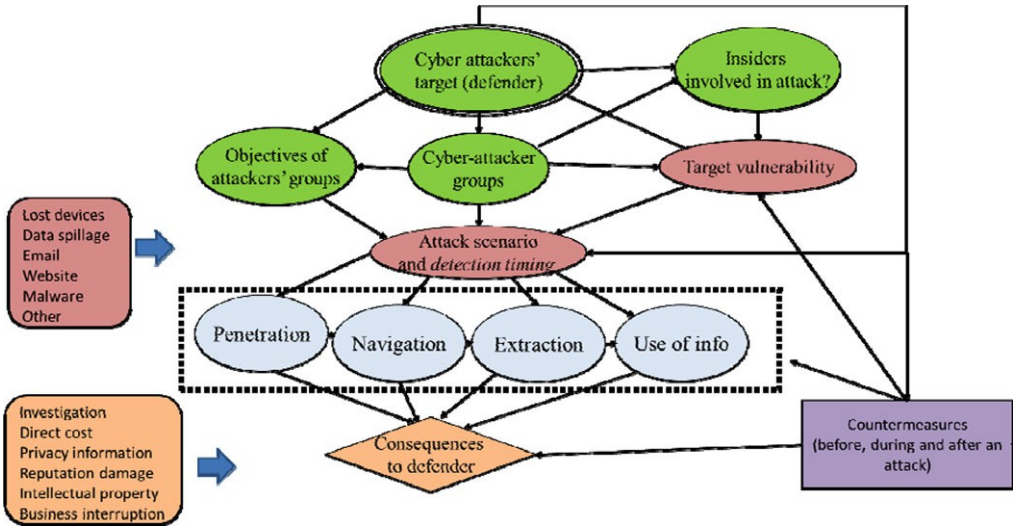


Fig. 1. Estructura del diagrama de decisión para la elección de opciones en materia de ciberseguridad. Adaptado de la ref. 6.

La mayoría de las prácticas de gestión de riesgos cibernéticos para la protección de infraestructuras pueden dividirse en tres grupos:

(1) **Estructurales** (composición y estructura de los sistemas ICS y de hardware)
(2) **Procedimentales** (gestión y funcionamiento del sistema)
(3) **Reactivas** (respuestas y control de daños tras la detección de un incidente)

Los métodos de análisis probabilístico de riesgos (PRA) adaptados están diseñados para evaluar la eficacia de cada una de estas opciones para organizaciones específicas con mayor detalle que las directrices generales. Este artículo se centra en la estructura general del problema del análisis de riesgos con tres ejemplos ilustrativos para abordar con mayor profundidad las compensaciones y prioridades: un análisis empírico de una base de datos de incidentes de ciberseguridad, un modelo de optimización diseñado para equilibrar la eficiencia operativa de un sistema con su protección frente a ciberataques (aplicado aquí a una red eléctrica inteligente) y un modelo de juego dinámico de algunas interacciones entre los operadores de infraestructuras y sus adversarios en el ciberespacio.

3. ANÁLISIS GENERAL DE RIESGOS E INCERTIDUMBRES

3.1. Riesgos y decisiones

El marco general de análisis de riesgos cibernéticos que aquí se presenta está diseñado para respaldar las decisiones de la defensores, dadas las incertidumbres a las que se enfrentan. Se trata de un modelo general del riesgo cibernético y de la eficacia de las diferentes contramedidas, que debe adaptarse al caso concreto de una organización determinada. Este modelo se representa en la figura 1 mediante un diagrama esquemático de influencias. Se basa en una interacción, reducida aquí a un movimiento por cada parte, entre el administrador de un sistema y posibles atacantes de diversa índole. Este diagrama de influencia representa una estructura modelo que debe desarrollarse más a fondo para reflejar las características de una organización de interés y de su sistema de información.

El responsable de la toma de decisiones suele conocer la mayor parte de la información relevante sobre la organización, de ahí que en la parte superior de la figura 1 aparezca un nodo determinista. Ese nodo determinista especifica el tipo de objetivo y sus activos. Puede tratarse, por ejemplo, de un laboratorio nacional, una empresa industrial que posea propiedad intelectual sensible, una empresa comercial con datos financieros como información de tarjetas de crédito, o un hospital vulnerable a la extorsión. Cada uno de estos tipos de organización tiene más o menos probabilidades de verse amenazado por diferentes tipos de atacantes: un país, individuos o grupos criminales. La vulnerabilidad[3] descrita en la figura 1 se refiere a posibles puntos de acceso y se caracteriza por una probabilidad de intrusión a través de dichos puntos. Como se muestra más adelante en el caso de la red inteligente, estos puntos de intrusión pueden identificarse mediante un análisis de la estructura de la

[3]El término «vulnerabilidad» se utiliza aquí para referirse a los posibles puntos de entrada en el sistema objetivo y, por lo tanto, a la probabilidad de una intrusión (a diferencia de su definición clásica como la capacidad de un sistema en el ámbito físico).

sistema de información y sus conexiones con las operaciones. Estos suelen ser conocidos o detectables, pero no siempre es así. Es posible que primero haya que abordar varias cuestiones y tratarlas como incertidumbres si es necesario:

- ¿Cuáles son los principales activos de la organización, dónde
  ¿Quiénes son y con quiénes están conectados? Por ejemplo, en 2012, empresas de tarjetas de crédito como MasterCard y Visa fueron víctimas de ataques informáticos contra procesadores externos. En ese caso, la cuestión es identificar la estructura y la ubicación de la información de los clientes, así como su vinculación con los clientes y vendedores que utilizan sus servicios.
  ¿Qué medidas de protección pueden considerarse, teniendo en cuenta las limitaciones prácticas y legales, contra una respuesta ofensiva?
- ¿Cuáles son los riesgos de un ataque interno, teniendo en cuenta
  ¿Quién tiene acceso a toda la red de información o a partes de ella? Este importante componente del riesgo depende de la naturaleza de la organización y de la gestión de su personal y contratistas (procedimientos de contratación, investigación de antecedentes, despido y acceso a la información). Un ejemplo es el ataque de Snowden a los sistemas de información de la Agencia de Seguridad Nacional (NSA) gestionados por Booz Allen, donde se concedió a personas internas un amplio acceso a estos archivos. Otro caso fue el del hackeo de las tarjetas de crédito de Target en 2013 por parte de contratistas de mantenimiento.[4]

Las incertidumbres restantes del modelo general pueden dividirse en tres grupos principales: datos demográficos de los atacantes, escenarios de ataque y sus consecuencias.

3.2. Características demográficas de los atacantes y puntos de entrada

Los atacantes varían en cuanto a recursos y sofisticación, desde hackers de bajo nivel hasta otros con gran experiencia y bien respaldados. El espectro incluye:

- Hackers y delincuentes de poca monta, a veces llamados «script kiddies» o «ankle biters», que por lo general no causan mucho daño, pero pueden, por ejemplo, alterar gravemente o desfigurar sitios web.
- Las organizaciones criminales que buscan obtener beneficios económicos mediante el robo de propiedad intelectual, información financiera o el rescate por datos robados. Algunas, por ejemplo, se han especializado recientemente en el «ransomware», que actualmente tiene como objetivo los hospitales, o el robo registros financieros, como la información de tarjetas de crédito.
- Atacantes persistentes patrocinados por el Estado que intentan obstaculizar el funcionamiento de organizaciones y países, y a robar propiedad intelectual buscando la intrusión inmediata o los medios para hacerlo más adelante.
- Otras empresas u organizaciones que pueden buscar beneficiarse de perjudicar a un competidor o de robar su propiedad intelectual mediante el espionaje industrial.
- Organizaciones terroristas que pueden simplemente tener con el objetivo de causar el máximo daño a las sociedades y obtener recursos para mantener sus operaciones financieras.
- Los empleados malintencionados, entre los que pueden figurar, o personas cuyos valores no coinciden con los de la organización, incluidas aquellas que simplemente buscan beneficios económicos.
- Contratistas, como los operarios de mantenimiento, que pueden tener o conseguir acceso a la red de información interna para perturbar el funcionamiento de la organización, ya sea por pura malicia o para vender la información sustraída.

En cada caso, las preguntas son: ¿Quiénes podrían ser estos atacantes?, ¿qué es lo que quieren?, ¿qué saben? y ¿de qué disponen? En el modelo global, una empresa concreta, basándose en su experiencia y en la naturaleza de sus activos, puede establecer una distribución de probabilidad sobre el tipo de atacantes a los que podría enfrentarse y sus métodos de ataque.

La siguiente incertidumbre para el defensor es la de sus vulnerabilidades y los puntos de entrada a través de los cuales los atacantes pueden penetrar en su sistema. Entre ellos se incluyen:

- Defectos involuntarios o «errores» en el software del defensor que pueden haberse introducido durante la programación inicial.
- Defectos intencionados que pueden introducirse en el hardware o el software a lo largo de la cadena de suministro por parte de posibles atacantes con la intención de utilizarlos posteriormente.
- Defectos periféricos: fallos o «bugs» en sistemas fuera del control del responsable de la toma de decisiones—que pueden introducirse a través de equipos conectados al sistema principal. Un virus en el ordenador portátil de un contratista puede utilizarse para penetrar en un sistema que, de otro modo, sería seguro si se conectan para prestar algún servicio y, como se ha mencionado anteriormente, los activos de una empresa de tarjetas de crédito pueden ser vulnerables al pirateo de procesadores de terceros.

[4] Se considera que esta categoría también incluye vulnerabilidades introducidas involuntariamente en el sistema por los empleados.

3.3. Escenarios de ataque

Por lo tanto, las distintas organizaciones pueden verse expuestas a diversos tipos de ataques, con distribuciones de probabilidad que dependen de la naturaleza de sus operaciones. Los escenarios de ataque más frecuentes incluyen la pérdida o el robo de dispositivos, la filtración de datos, los ataques mediante correos electrónicos maliciosos (phishing), los ataques a sitios web y el malware introducido a través de la navegación web o de memorias USB. La base de datos Common Vulnerabilities and Exposures (CVE), recopilada por MITRE Corporation, ofrece un sistema de puntuación numérica diseñado para clasificar la probabilidad de que diferentes fallos de software conocidos puedan utilizarse para causar daños o proporcionar a un adversario el control o el acceso a un sistema.[13]

Un ataque exitoso, por ejemplo, cuyo objetivo sea robar o dañar la propiedad intelectual, suele constar de cuatro fases (recuadro punteado de la fig. 1):

- Entrar en el sistema
- Desplazarse lateralmente dentro del sistema para obtener acceso no autorizado a sus diferentes partes
- Causar daños tanto al software como al hardware
- Recuperar, extraer y utilizar la información de interés

Se pueden implementar contramedidas para hacer frente a cada una o varias de estas fases de ataque, incluyendo cortafuegos para proteger contra el acceso, un «laberinto» en el sistema para dificultar la libre navegación, barreras contra la exfiltración y la supervisión del uso de datos para detectar el ataque lo antes posible y minimizar el daño (por ejemplo, la pérdida de archivos de tarjetas de crédito robadas). Las materializaciones de cada uno de estos nodos probabilísticos y los correspondientes nodos de decisión de la organización objetivo representan las diferentes formas en que un adversario específico puede atacar una red concreta y sus posibilidades de éxito.

3.4. Impactos del ataque

El impacto de un ataque exitoso depende, por tanto, de la naturaleza de la organización y de los activos dañados o sustraídos, así como de la eficacia de las medidas de control de daños. Como se ha mencionado anteriormente, un factor clave es el tiempo transcurrido entre un incidente y su descubrimiento. Por ejemplo, la pérdida de información de tarjetas de crédito puede ser detectada por las propias víctimas, pero luego pueden pasar semanas hasta que los bancos y las organizaciones controlen eficazmente el daño. Por lo tanto, los costes de los ciberataques para las operaciones comerciales y la reputación del defensor son muy variables dependiendo de la naturaleza y el valor de los objetivos. Las repercusiones en las operaciones empresariales pueden ser considerables, con pérdidas de producción durante el tiempo de inactividad, la investigación del incidente, las medidas correctivas y la pérdida de activos, como la tecnología crítica en una empresa espacial. Además, la organización puede sufrir un daño a su reputación, que, en algunos casos, puede medirse por la pérdida de valor del precio de las acciones; pero parece que este último efecto ha sido de alguna manera limitado, como ocurrió, por ejemplo, con el ataque de 2013 contra Target, donde la disminución del valor de la empresa fue inmediata, pero relativamente menor y de corta duración.

Según nuestro conocimiento, la evaluación de los daños causados por los ataques ha sido hasta ahora principalmente cualitativa. Sin embargo, existen técnicas cuantitativas, analíticas y económicas que pueden utilizarse para agregar estos impactos de los ataques, basándose bien en datos reales o en opiniones de expertos. Una medida única de las pérdidas monetarias puede ser una simple función aditiva si se asume que estos costes son independientes; pero, a falta de otra medida, la disposición a pagar de los responsables de la toma de decisiones para evitar estas pérdidas, o los costes de los seguros y reaseguros, pueden utilizarse como sustitutos.

En este contexto, las estadísticas resumidas de pérdidas, como la media y la varianza, no son suficientes para respaldar una decisión racional y pueden resultar engañosas, ya que las distribuciones de pérdidas pueden presentar colas pesadas. Por lo tanto, los beneficios de las inversiones basados en un único valor de este tipo pueden verse distorsionados y los recursos pueden asignarse de forma inadecuada.

3.5. Ilustraciones

A continuación se ilustran diferentes partes de este modelo general mediante tres ejemplos centrados en aspectos específicos del método y características analíticas (tratamiento de estadísticas, análisis de redes y dinámica de ataque y defensa).

- El primer ejemplo es un análisis estadístico de una base de datos real sobre ciberataques repetidos contra una gran organización estadounidense. Entre ellos se incluyen ataques maliciosos por correo electrónico, ataques a sitios web, incidentes de fuga de datos, dispositivos perdidos o robados e incidentes de malware. El reto consiste en extender las curvas de riesgo al ámbito en el que aún no se han producido ataques, basándose en un análisis probabilístico de escenarios extremos.
- El segundo ejemplo es un modelo probabilístico de ataques a una red eléctrica inteligente, con una ilustración teórica basada en un análisis de la red y del sistema. La pregunta aquí es: ¿qué grado de inteligencia es suficiente y en qué momento es necesario un

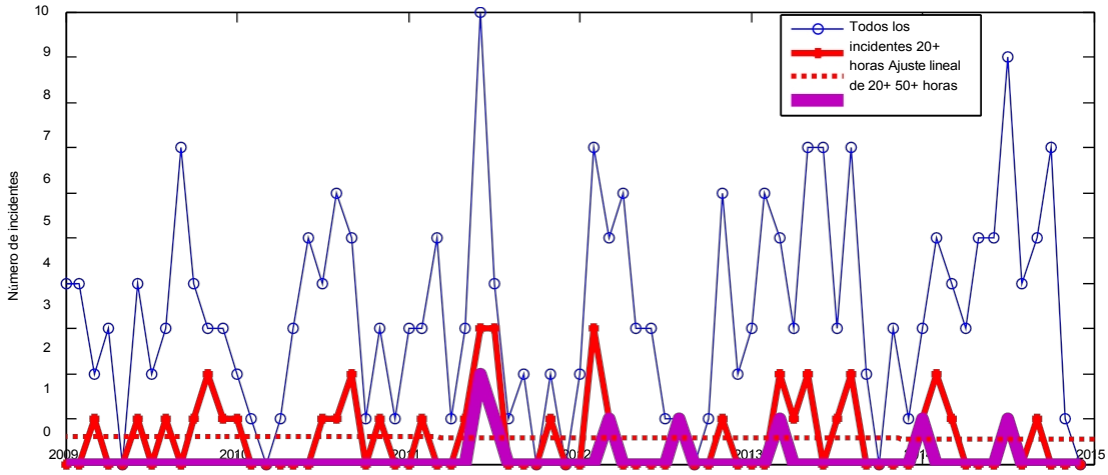


Fig. 2. Tendencia de fuga de datos en la organización considerada a lo largo de seis años.

¿La conexión va a generar costes de riesgo marginales que superarán sus beneficios?

- El tercer ejemplo es un modelo dinámico y probabilístico diseñado para orientar el momento de las decisiones de un defensor en la gestión de un sistema de software industrial que debe mejorarse periódicamente para evitar que los adversarios interrumpan las operaciones o roben propiedad intelectual. La ilustración teórica que se presenta aquí es la gestión del ordenador que controla el sistema de distribución de agua de una ciudad.

4. EJEMPLO N.º 1: ANÁLISIS EMPÍRICO DE UN CONJUNTO DE DATOS SOBRE CIBERATAQUES

4.1. Análisis estadístico

Los autores tuvieron acceso confidencial a una base de datos de ciberataques contra una gran organización con sede en Estados Unidos. Esto nos permitió ilustrar nuestro método de análisis de riesgos, incluyendo, en primer lugar, un análisis estadístico de un suceso pasado y, a continuación, una extrapolación de los resultados a la posibilidad de que se produzcan sucesos más graves en el futuro.[5] Esta base de datos incluye más de 60 000 ciberataques durante un periodo reciente de seis años (2009-2015). La gravedad de un ataque se mide simplemente en horas de investigación. Analizamos estos datos para determinar si la frecuencia de los ataques había aumentado con el tiempo, y para comparar algunas opciones para reducir el riesgo cibernético actual.

Estos registros de ataques rara vez se hacen públicos, pero en algunas organizaciones existen grandes cantidades de datos. Reflejan el pasado, pero pueden utilizarse, junto con cierta información adicional, para evaluar la frecuencia y el impacto de sucesos similares en el futuro. El riesgo futuro dependerá de la evolución —si la hubiera— de los métodos de ataque y de la eficacia de las medidas defensivas. En la base de datos analizada, los ataques se clasificaron en diferentes categorías relevantes para esa organización específica: dispositivos perdidos o robados, fugas de datos, ataques por correo electrónico («phishing»), ataques a sitios web, malware y otros tipos menos frecuentes, como los ataques de tipo «shell-shock». Centrándonos en la fuga de datos, la figura 2 representa la frecuencia y los costes de todos los incidentes de fuga de datos, incluidos aquellos que requirieron más de 5, 20 y 50 horas de investigación. Según una regresión lineal representada por la línea punteada, la tasa de incidentes a lo largo de seis años en esa organización parece relativamente estable.

La fig. 3 se centra en otro tipo de ataque (incidentes de correo electrónico malicioso) en la misma organización. Muestra la función de distribución acumulativa complementaria (curva de riesgo) del tiempo de investigación que requieren estos incidentes, representada mediante una línea discontinua basada en un ajuste de ley de potencias de los datos. El análisis estadístico muestra que, incluso si solo se tiene en cuenta el tiempo de investigación de los incidentes, las pérdidas deben caracterizarse por una distribución de cola pesada.[6] Un valor atípico que podría

[5] Por motivos de confidencialidad y a petición de la misma, no se revelan aquí el nombre de dicha organización ni algunas características de esta base de datos.

([6]) En realidad, se necesita un modelo de costes más completo para caracterizar las consecuencias de los ataques. En la organización considerada,

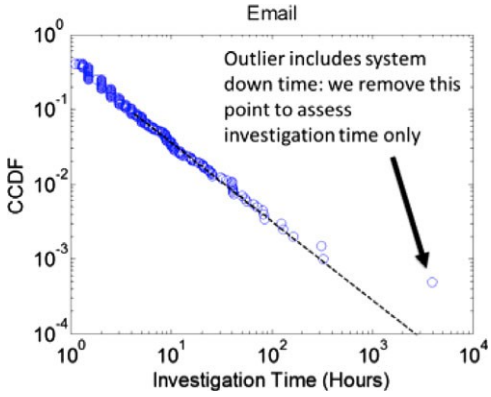
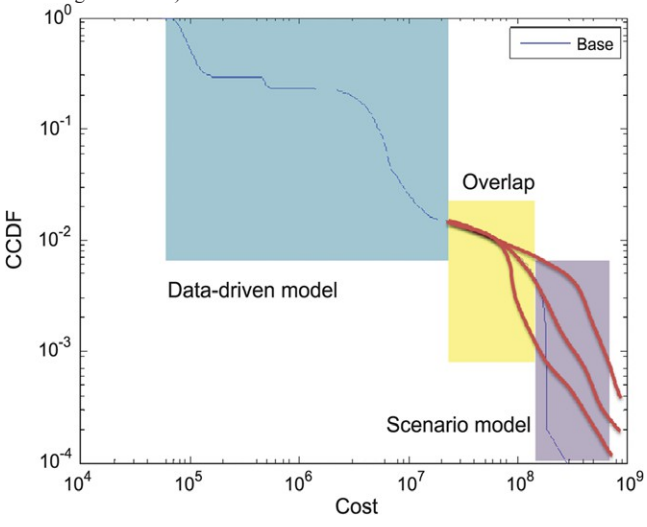


Fig. 3. Modelización de la distribución de los tiempos de investigación de los incidentes de correo electrónico en nuestra base de datos. Curva de riesgo obtenida ajustando una distribución de ley de potencias a los datos estadísticos.

se ha requerido un análisis de costes más completo que no se incluyó en el ajuste de la curva. El análisis sugiere dos cosas: en primer lugar, que una evaluación probabilística completa del riesgo (en contraposición a una simple cifra descriptiva) es fundamental para respaldar decisiones racionales y eficientes; en segundo lugar, que un análisis estadístico de los incidentes pasados por sí solo no ofrece una descripción completa del riesgo de futuros ataques.

incluye no solo el tiempo de investigación, sino también la interrupción de la actividad empresarial, la pérdida de información privada, la pérdida de propiedad intelectual, los costes directos y el daño a la reputación.[5] Siguen existiendo grandes incertidumbres, pero se puede encontrar información relevante en la literatura académica, los informes públicos y las opiniones de expertos en la materia (véase, por ejemplo, Cavusoglu *et al.*[29]).



4.2. Los límites de la estadística y las extensiones probabilísticas

Dada la naturaleza de los incidentes observados y la rápida evolución del mundo cibernético, siguen existiendo dudas sobre el límite máximo de las posibles pérdidas cibernéticas y la cola de la distribución de los daños. Por definición, los problemas graves que aún no se han producido no aparecen en los datos existentes, pero estos posibles ataques deben incluirse en un análisis de riesgos completo, y es posible que haya que implementar medidas especiales de ciberdefensa para hacer frente a estos casos. Para ofrecer una visión completa, es necesario, por tanto, identificar posibles escenarios de ataques más graves que los que se han sufrido hasta ahora y evaluar los riesgos correspondientes.

Estos sucesos extremos se incluyen en los resultados mediante un análisis probabilístico de posibles escenarios, teniendo en cuenta toda la información disponible. Algunos de los elementos de estos escenarios a veces ya existen en la base de datos (por ejemplo, intentos de explotar una vulnerabilidad específica sin alcanzar el nivel más alto posible de daño). Estos datos estadísticos se utilizan para informar parcialmente sobre la probabilidad de escenarios de ataques extremos. Se complementan con opiniones de expertos, si es necesario, para proporcionar un análisis completo de estos escenarios de graves consecuencias. Otras evaluaciones del riesgo de ataques de gran envergadura se basan principalmente en opiniones de expertos; por ejemplo, la capacidad de un adversario determinado para acceder a funciones esenciales de algunos sistemas de comunicación críticos de EE. UU., con el efecto de causar niveles muy altos de daño. Entre ambos extremos, existe así una zona de «superposición» entre la parte de la curva basada en datos y el modelo de escenarios que nunca se han producido hasta ahora (Fig. 4).

Fig. 4. La combinación de un modelo basado en datos con un modelo basado en escenarios implica la superposición de las dos curvas de riesgo.

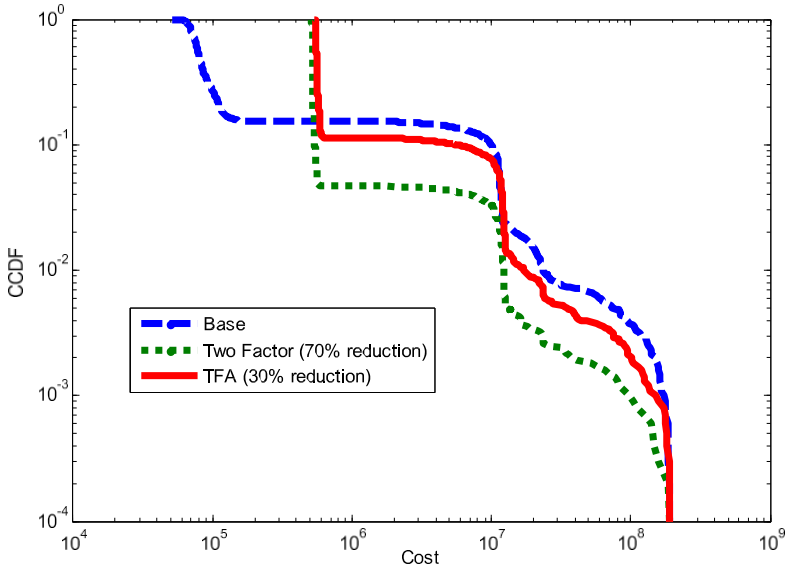


Fig. 5. Curvas de riesgo que ilustran las ventajas de la autenticación de dos factores en dos niveles diferentes de implementación.

La siguiente cuestión consiste en estimar la eficacia de las medidas de protección para todo el espectro de niveles de gravedad de los ataques. El cálculo de los beneficios se ilustra en la figura 5 mediante el caso de un requisito de TFA en dos niveles de implementación para el acceso a diferentes servicios, como redes privadas virtuales, correo web o estaciones de trabajo. Se ejecuta una simulación de Monte Carlo para obtener curvas de riesgo que comparan la eficacia de estas dos opciones, medida por los beneficios de reducción del riesgo en todo el espectro de gravedad de los incidentes. El caso base (línea azul) representa el riesgo actual, mientras que las líneas verde y roja muestran las curvas de riesgo que se obtienen, suponiendo que la implementación de una TFA elimina el 30 % (verde) o el 70 % (roja) de los ataques exitosos. Este análisis probabilístico del riesgo cibernético, basado en estadísticas existentes y ampliado a eventos extremos, puede replicarse en otras organizaciones si estas han recopilado datos estadísticos sobre ciberataques y pueden recurrir a las opiniones de expertos internos para caracterizar escenarios de pérdidas graves. De este modo, se puede comparar la eficacia de las medidas de seguridad para todo un espectro de... gama de opciones de gestión de riesgos.

5. EJEMPLO N.º 2: UN PROBLEMA DE RED: EL CASO DE LA RED ELÉCTRICA Y LOS COSTES Y RIESGOS DE LA «INTELIGENCIA»

5.1. Modelización del riesgo cibernético en una red eléctrica «inteligente»

El apagón ocurrido en Ucrania el 23 de diciembre de 2015 —el primer caso conocido de un ciberataque que provocara un corte de suministro eléctrico— demuestra el valor de cuantificar los riesgos y los beneficios de una red eléctrica interconectada «inteligente». En este incidente, tres empresas ucranianas de distribución eléctrica fueron víctimas de un ataque coordinado que incluyó (1) una campaña de spear-phishing para introducirse en las redes corporativas; (2) programas de registro de pulsaciones de teclas para obtener credenciales de acceso a las redes de sistemas de control industrial (ICS); y (3) el acceso a los sistemas de control de supervisión y adquisición de datos (SCADA), que permiten la supervisión y el control remotos y que se utilizaron para secuestrar interfaces hombre-máquina y emitir órdenes para abrir interruptores.[14] Un análisis inicial sugiere que estas tres empresas de distribución pudieron haber sido el objetivo *porque* eran las más conectadas.[15] Concretamente, el nivel de automatización y conectividad dentro de sus redes de distribución permitió a los atacantes no solo pasar de la red empresarial a la red de control, sino también obtener el control remoto de los sistemas SCADA para abrir los interruptores de las subestaciones. Esta conectividad permitió a los atacantes desconectar 30 subestaciones de distribución, lo que provocó que aproximadamente 225 000 residentes se quedaran sin suministro eléctrico durante varias horas. Esta intrusión se produjo a pesar de las sólidas medidas de ciberseguridad que las empresas de distribución habían implementado, incluida una red de control bien segmentada de la red empresarial y protegida por un robusto cortafuegos.

De hecho, la aparición de la red inteligente promete aportar numerosos beneficios al funcionamiento general de la distribución eléctrica en América del Norte, entre ellos una mayor eficiencia, una mayor fiabilidad,

una mejor integración de las fuentes de energía renovables y más opciones para los consumidores de electricidad. Sin embargo, debido al aumento del número de interconexiones, las mismas tecnologías que mejoran el rendimiento de una red inteligente también la exponen a amenazas digitales como los ataques de denegación de servicio, el robo de propiedad intelectual, la invasión de la privacidad y el sabotaje de una infraestructura nacional crítica. La «inteligencia» aumenta el número de posibles puntos de acceso y vulnerabilidades y, dada la naturaleza integrada de estos sistemas ciberfísicos, los fallos de la red provocados por ciberataques pueden propagarse en cadena a otras infraestructuras críticas —por ejemplo, redes de transporte, sistemas de tratamiento de aguas o sistemas financieros— y causar daños físicos extensos y perturbaciones económicas.

Por lo tanto, las ventajas de una mayor conectividad deben sopesarse frente al riesgo de una mayor exposición a los ciberataques, ahora que los actores del sector eléctrico se plantean modernizar la arquitectura tradicional de la red eléctrica mediante la incorporación de tecnologías de red inteligente y nuevos componentes inteligentes. En algún momento, los responsables de la toma de decisiones deben preguntarse: ¿qué grado de inteligencia es suficiente? El modelo PRA descrito anteriormente permite cuantificar el aumento del riesgo de un ciberataque a la red eléctrica (tanto en términos de probabilidad como de consecuencias) a medida que esta se vuelve «más inteligente». En este caso, la probabilidad de una intrusión en el sistema y la capacidad de los atacantes para moverse por él —ambos factores clave para el éxito de un escenario de ataque— están vinculadas al riesgo cibernético global en función del nivel de conectividad. Los beneficios de las conexiones adicionales se evalúan por separado.

Para determinar el grado óptimo de conectividad, consideramos, en primer lugar, una red eléctrica física representada como un grafo no dirigido, en el que cada nodo es un punto eléctrico distinto de la red (generadores, consumidores o subestaciones) y los arcos son las líneas de transmisión que los unen (véase la fig. 6). En cualquier momento, el operador del sistema puede optar por conectar un subconjunto de nodos a la nube, creando una red de información superpuesta sobre la red física. Sin embargo, cada nueva conexión a un nodo de información es un vector potencial de intrusión cibernética, y cada enlace de información ofrece una oportunidad para un ciberataque que puede propagarse a los nodos adyacentes de la red física. Al considerar secuencialmente cada conexión incremental, este modelo de red permite discretizar la decisión de la empresa de servicios públicos sobre el grado de «inteligencia» que debe alcanzar su sistema. Los operadores del sistema y las autoridades que equilibran la distribución eléctrica suelen agrupar a los clientes en grandes cargas. Por lo tanto, tiene sentido en el modelo agrupar agrupar la carga total del sistema en nodos agregados de la misma manera. Nuestro objetivo es ilustrar cómo el enfoque PRA puede utilizarse para ayudar a los operadores de red a priorizar las medidas de protección, teniendo en cuenta los costes y los beneficios de los aumentos marginales de conectividad.

Intuitivamente, a medida que la red eléctrica se vuelve más inteligente, cabe esperar que sucedan dos cosas:

(1) **El beneficio marginal disminuirá**. En el caso de muchas tecnologías de redes inteligentes, la mayor parte de los beneficios se puede obtener con un nivel moderado de conectividad. Por ejemplo, un informe reciente reveló que la instalación de tecnología de reducción de tensión para el ahorro energético en el 40 % de las líneas de distribución permite alcanzar el 80 % del beneficio que se obtendría al actualizar todas las líneas.[16] Se ha observado una tendencia similar en los contadores inteligentes que conforman la infraestructura de medición avanzada.[17]

(2) **El riesgo de ciberseguridad aumentará**. Aunque la forma de esta dependencia no es evidente a primera vista, una mayor conectividad puede provocar un aumento tanto de la probabilidad de ciberataques (debido al incremento del número de vías de ataque) como de sus consecuencias (debido a una mayor interdependencia entre los componentes de control de la red eléctrica).

El PRA que aquí se propone para cuantificar esta relación de compensación en diversas tecnologías de redes inteligentes se muestra en la figura 7. Este enfoque complementa los datos estadísticos existentes con modelos de ingeniería de la red eléctrica, modelos estocásticos, simulaciones de escenarios de ataque y análisis de redes, con el fin de rastrear la evolución dinámica de los modos de fallo provocados por las vulnerabilidades cibernéticas. En un primer paso, realizamos un análisis del sistema para identificar clases de escenarios de fallo que pueden inducirse al explotar las vulnerabilidades cibernéticas en una red de red inteligente, según la opinión de expertos del sector[18] y los incidentes conocidos. A continuación, utilizamos un modelo de despacho económico para evaluar el beneficio financiero y el riesgo de una mayor inteligencia, basándonos en la física y la economía de su efecto sobre el sistema eléctrico. Los resultados del análisis económico se utilizan a continuación como datos de entrada para un modelo probabilístico que sirve para determinar una estrategia de asignación óptima de los recursos de ciberseguridad. Por último, se utiliza un modelo de análisis de decisiones (que asume la neutralidad del riesgo) para comparar la eficacia de posibles medidas de mitigación de riesgos, tales como la mejora de las defensas cibernéticas, la segmentación de las redes de infraestructura crítica, la instalación de sistemas de respaldo y la ciberseguridad

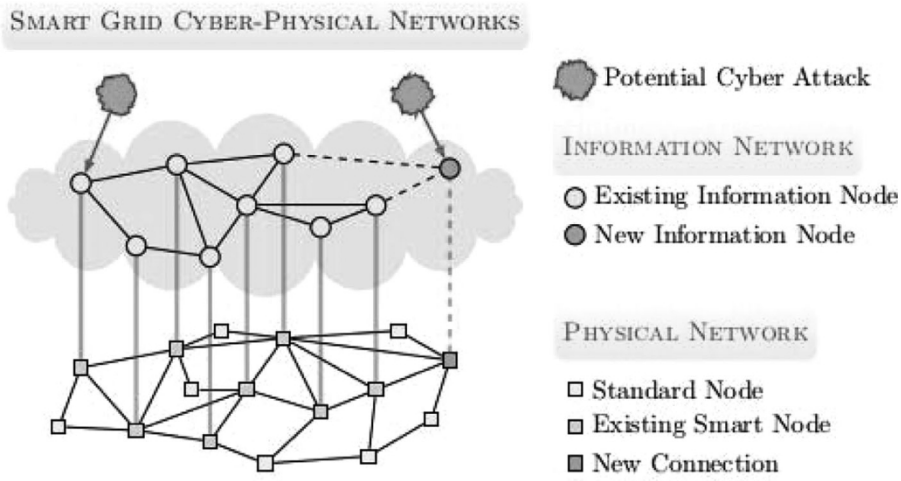


Fig. 6. Resumen conceptual de un sistema en el que la empresa eléctrica considera secuencialmente los beneficios marginales y los riesgos de conectar un nodo adicional a su red de red inteligente.

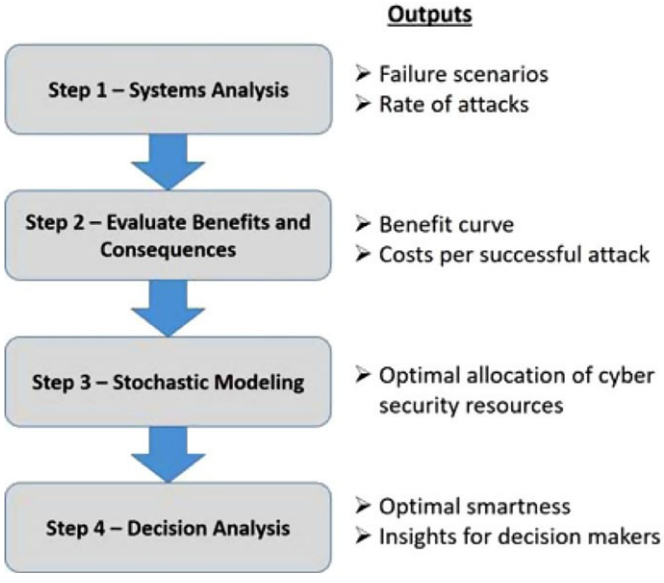


Fig. 7. Resumen de nuestro enfoque PRA para el análisis de riesgos cibernéticos de una red inteligente.

A partir de estos resultados, podemos evaluar el grado óptimo de conectividad.

Este enfoque de modelización presenta numerosas ventajas: proporciona herramientas que facilitan la combinación de datos estadísticos con opiniones de expertos y modelos de ingeniería; permite a los responsables de la toma de decisiones realizar un análisis de sensibilidad de los parámetros clave, incluyendo su propia tolerancia al riesgo y otros factores de seguridad específicos de la organización; es muy adecuado para gestionar los numerosos niveles de incertidumbre que introducen la complejidad de los sistemas de ingeniería y la influencia del comportamiento humano; e indica en qué deben centrarse los esfuerzos de modelización adicionales.

5.2. Aplicación ilustrativa del modelo de optimización

Aplicamos este modelo a una red eléctrica ilustrativa representativa de una porción de tres estados de la Interconexión Occidental, tal y como la estudiaron anteriormente Larrosa *et al.*[(19)7] A continuación, consideramos la decisión relativa al grado en que integrar la respuesta a la demanda en cualquier subconjunto de 10 consumos

[7] Se trata de un ejemplo puramente ilustrativo de conexiones de red interestatales, destinado a mostrar el potencial de efectos en cascada de los fallos a través de estas redes.

Tabla I. Escenarios de fallos cibernéticos provocados por la incorporación de la respuesta a la demanda

Escenario de fallo	Impacto en el modelado
FS1 – Pérdida de conciencia situacional	El nodo inteligente ya no mitiga el impacto de los cortes en las líneas de transmisión.
FS2 – Corte local activado de forma remota	No se cumple el coste de 3,76 $ por kWh de demanda, según lo determinado por el periodo de cuatro horas más alto para ese nodo.
FS3 – Denegación de servicio que bloquea los mensajes de respuesta a la demanda	La carga máxima aumenta un 2 % con respecto al perfil normal (sin respuesta a la demanda).
FS4 – Manipulación del precio/contador	Los precios efectivos para los clientes se reducen en un 1 % con respecto a los valores nominales, lo que disminuye los ingresos de la empresa de servicios públicos.
FS5 – Robo de información privada	Hay un coste fijo de 2300 $ por cada nodo.

Nota: Los costes de la filtración de datos se basan en los costes per cápita de informes recientes sobre filtraciones de datos. [23]

nodos. La respuesta a la demanda es un procedimiento emergente de las redes inteligentes que permite a las empresas de servicios públicos utilizar señales de precios para influir en el comportamiento de los clientes, induciendo una menor demanda de electricidad cuando los costes operativos son elevados (por ejemplo, durante los picos de demanda) o cuando la fiabilidad del sistema se ve comprometida (por ejemplo, durante un corte de suministro inesperado u otra contingencia del sistema). Debido a la sobrecarga de comunicación necesaria para respaldar y habilitar este proceso, la respuesta a la demanda es un buen ejemplo de tecnología de red inteligente en la que el aumento de la conectividad proporciona beneficios a los operadores del sistema, al tiempo que introduce riesgos cibernéticos, ya que aumenta el número de vectores de ciberataque.[20]

La «inteligencia» de la red se mide en una escala de 0 a 1, como la proporción de nodos equipados con tecnología de respuesta a la demanda, donde 1 significa que todos los nodos están conectados al centro de control. A continuación, se calculan los beneficios y riesgos de una mayor inteligencia utilizando un modelo de despacho económico del mercado eléctrico, que calcula la forma más barata de generar la electricidad suficiente para satisfacer la demanda diaria, sujeto a las restricciones del sistema, basándose en los precios actuales de la electricidad y en los datos de demanda de los clientes de la región.[21] Concretamente, los beneficios derivados de la reducción de la demanda máxima y de una reacción más rápida ante contingencias inesperadas del sistema se calculan adaptando técnicas analíticas de Kwag y Kim,[22] quienes demostraron un modelo teórico que incorpora la respuesta a la demanda en el algoritmo de despacho económico para hallar el coste operativo óptimo del sistema para una empresa de servicios públicos con funciones de coste de generación cuadráticas. Para modelar los riesgos asociados al aumento de la inteligencia, consideramos cinco clases de escenarios de fallos de ciberseguridad relacionados con la incorporación de tecnologías de respuesta a la demanda, basados en los identificados en un análisis reciente de la Na-Organización Nacional de Recursos para la Ciberseguridad del Sector Eléctrico (NESCOR).[18] Los cinco escenarios de fallo se enumeran en la Tabla I, junto con una descripción de cómo evaluamos su impacto financiero en los costes operativos diarios de la empresa de servicios públicos.

Para calcular los costes previstos para la empresa de servicios públicos en caso de ciberataques exitosos, combinamos, para cada escenario, su impacto financiero con su puntuación de probabilidad, tal y como la define NESCOR. Esta puntuación, que oscila entre 0 y 45, representa la facilidad con la que un agente malicioso podría provocar ese fallo concreto. Para utilizar esa métrica como indicador de la probabilidad de éxito de un tipo específico de intento de ciberataque, escalamos esta puntuación al rango [0,1]. Basándonos en la física y la economía, calculamos entonces el riesgo cibernético asociado a cada nueva conexión como el aumento esperado de los costes de riesgo para los cinco escenarios de fallo considerados. Suponemos que las decisiones de conexión se toman secuencialmente en orden decreciente de la relación beneficio marginal/coste de riesgo. Repetimos este análisis para cualquier número de conexiones posibles a fin de obtener la curva de beneficio, la curva de riesgo y la compensación resultante, tal y como se muestra en la figura 8. El nivel óptimo de inteligencia es el punto en el que el beneficio marginal es igual al coste de riesgo marginal. En este caso ilustrativo, el óptimo es conectar 6 nodos de un total de 10.

Por lo tanto, el aumento de la inteligencia resulta beneficioso hasta el punto en que el riesgo marginal de una nueva conexión cibernética —y la vulnerabilidad que conlleva— supere sus beneficios incrementales. Una vez más, el modelo aquí presentado es una ilustración genérica del método descrito anteriormente. Debe adaptarse a casos específicos para respaldar las decisiones incrementales de los gestores de un sistema a la hora de aumentar o no su conectividad, teniendo en cuenta sus enlaces internos y los posibles efectos en cadena de un fallo en una red global.

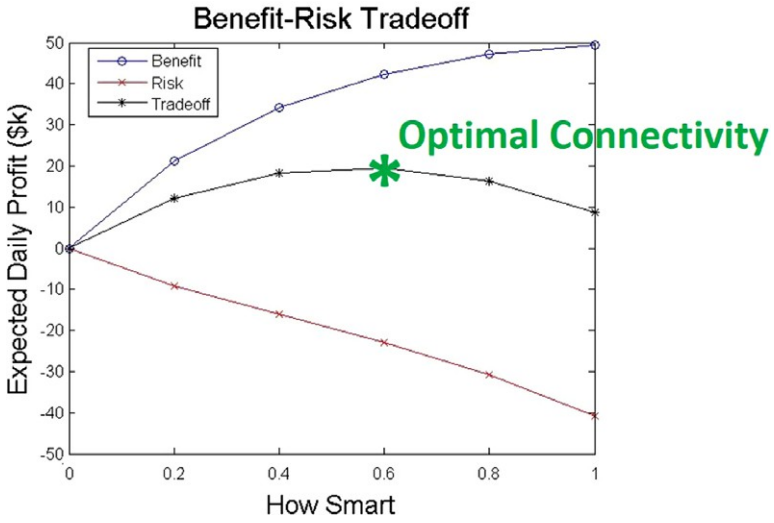


Fig. 8. Compromiso entre beneficios y riesgos del aumento de la conectividad para una red más inteligente en el margen (¿cuán inteligente es lo suficientemente inteligente?).

6. EJEMPLO N.º 3: MANTENERSE POR DELANTE DE LOS ADVERSARIOS: MODELOS DINÁMICOS DE ADOPCIÓN Y RECONFIGURACIÓN TECNOLÓGICA

6.1. Frustrar o retrasar un ciberataque cambiando el software

Consideremos ahora el caso del responsable de una red de distribución de agua que sospecha que sus operaciones se ven amenazadas por la posibilidad de un ciberataque y baraja la posibilidad de actualizar o cambiar su software operativo con el fin de retrasar o frustrar dicho ataque. En este último ejemplo, utilizamos un análisis de riesgo probabilístico (PRA) dinámico para modelar la interacción entre esas decisiones de gestión de riesgos y las de los adversarios. Las decisiones de adoptar, modificar o reconfigurar el software operativo se tratan como un problema de control estocástico basado en el vínculo entre las decisiones del operador del sistema y las del adversario.[8]

6.2. Un modelo dinámico de protección de software

La antigüedad del software y su influencia en las decisiones cibernéticas se representan mediante un modelo de control estocástico. Un análisis empírico de las vulnerabilidades de software en la base de datos CVE[(13)] muestra que los ciberataques pueden modelarse como procesos de Poisson en el caso de los paquetes de software habituales. Otros factores fundamentales para las decisiones de cambio o actualización de software incluyen la naturaleza del software actual y sus vulnerabilidades conocidas, así como la disponibilidad de nuevo software y parches de software. Estos factores se consideran aquí como características de los estados del sistema.

Las transiciones entre los estados de este sistema se describen mediante un modelo de Markov. Estimamos la probabilidad de nuevas vulnerabilidades basándonos en datos de la Base de Datos Nacional de Vulnerabilidades (NVD), respaldada por el Instituto Nacional de Estándares y Tecnología (NIST).[(24)] También evaluamos la «vida útil» del software y la tasa de aparición de nuevos ataques a través de vulnerabilidades conocidas solo por los adversarios («vulnerabilidades de día cero») basándonos en datos empíricos de Bilge y Dumitras.[(25)] Estimamos el tiempo transcurrido entre el lanzamiento de un software y la publicación de las primeras vulnerabilidades basándonos en el historial de ese software. Clark *et al.*[(26)] demuestran que la familiaridad de un adversario con versiones «parentales» anteriores de un software puede reducir el tiempo que le llevará descubrir nuevas vulnerabilidades en el sistema del defensor. La disponibilidad retrasada de parches para nuevas vulnerabilidades —el periodo durante el cual los sistemas no pueden protegerse— se modela basándose en el trabajo de Nappa *et al.*[(27)] La disponibilidad de parches de software y el descubrimiento de nuevas vulnerabilidades de software se consideran variables de estado exógenas, fuera del control del operador del sistema pero que forman parte de los estados del sistema.

Las consecuencias de un ciberataque se abordan utilizando los métodos probabilísticos presentados en las secciones anteriores. El Sistema Común de Puntuación de Vulnerabilidades (CVSS) ofrece un método para evaluar el impacto y las consecuencias de diferentes vulnerabilidades.[(28)] El análisis de la puntuación CVSS

[8] En realidad, hay otros factores que también son clave para el éxito de la gestión del software, incluida, en primer lugar, su calidad. No tenemos en cuenta los casos en los que un nuevo software pueda ser defectuoso.

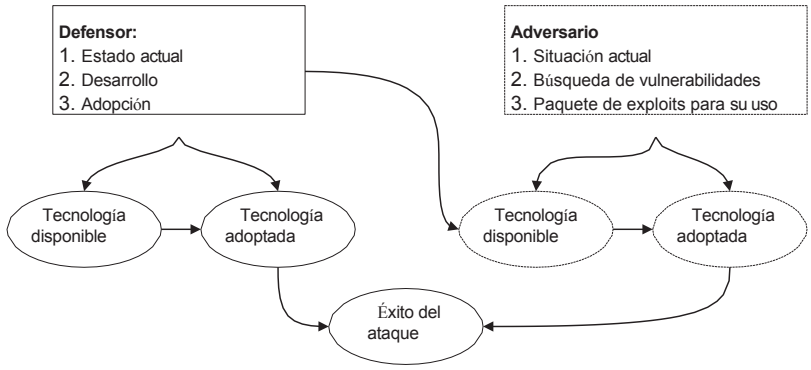


Fig. 9. Estructura simplificada del modelo de decisiones de desarrollo tecnológico por parte de un defensor y de ataque por parte de un adversario a través de una vulnerabilidad cibernética (las líneas discontinuas representan las incertidumbres para el defensor).

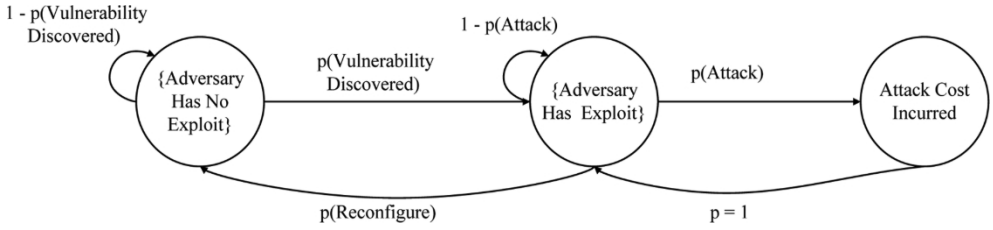


Fig. 10. Un ejemplo sencillo de modelo de Markov de ciberataques.

para diversas vulnerabilidades en el NVD permite calcular la probabilidad de existencia de diferentes tipos de vulnerabilidades y su gravedad en un intervalo de tiempo determinado.

La reconfiguración del software mediante la instalación de una nueva versión o el cambio de los ajustes del software reduce la probabilidad de que los atacantes tengan acceso a una vulnerabilidad que conocen y pueden explotar. En la práctica, la reconfiguración del software puede anular el trabajo de los atacantes, obligándolos a reiniciar sus esfuerzos para explotar un sistema. Por lo tanto, esperar demasiado tiempo para actualizar los sistemas de software aumenta su vulnerabilidad ante un ataque, pero las actualizaciones frecuentes pueden resultar costosas. La reconfiguración suele requerir un tiempo de inactividad de la infraestructura física que controla un sistema de software (por ejemplo, electricidad, gas, agua o tráfico). También implica costes económicos directos para los operadores del sistema si deciden adquirir nuevas licencias de software y volver a formar a su personal. Utilizamos un modelo de análisis de decisiones para determinar cuándo un operador debe reconfigurar o aplicar parches al sistema, basándonos en las variables de estado descritas anteriormente, con el fin de garantizar el nivel deseado de ciberseguridad.

En la figura 9 se representan los elementos de un modelo simplificado de ciberataque en el que intervienen tanto un atacante como un defensor, así como las interdependencias entre las decisiones tecnológicas de ambas partes. En cada periodo de tiempo, los defensores pueden decidir mantener el statu quo de su tecnología, desarrollar nuevas configuraciones tecnológicas o adoptar nuevos productos; sin embargo, la adopción de nuevo software también puede introducir nuevas vulnerabilidades que el atacante puede aprovechar. Por lo tanto, ambas partes pueden intentar mejorar sus tecnologías, y el problema para el defensor es mantenerse por delante del atacante.

Para ilustrar este método general, utilizamos un modelo de Markov discreto que refleja la evolución de una tecnología cibernética y su gestión (véase la fig. 10). El modelo incluye dos estados básicos (si el adversario tiene o no acceso a una vulnerabilidad conocida) y un tercer estado en el que se produce un ataque.

Volviendo al ejemplo de un único ordenador que controla el sistema de distribución de agua de una ciudad, en cada intervalo de tiempo, el operador del sistema tiene dos opciones: mantener el sistema actual o reconfigurarlo para frustrar los intentos de un adversario de penetrar en él. El administrador del sistema evalúa la probabilidad por unidad de tiempo de que el adversario encuentre una vulnerabilidad (por ejemplo, basándose en el tiempo medio entre dos eventos de este tipo) y sea capaz de completar el desarrollo de una nueva capacidad de ataque para explotar dicha vulnerabilidad. A continuación, el operador actualiza la probabilidad de que el adversario utilice esta vulnerabilidad descubierta con nuevas capacidades, del mismo modo que se estimaría la fiabilidad de un sistema físico en deterioro. Si el administrador del sistema (el defensor) decide reconfigurar el sistema, se trataría de un «nuevo comienzo», que eliminaría cualquier vulnerabilidad detectada previamente por el adversario.

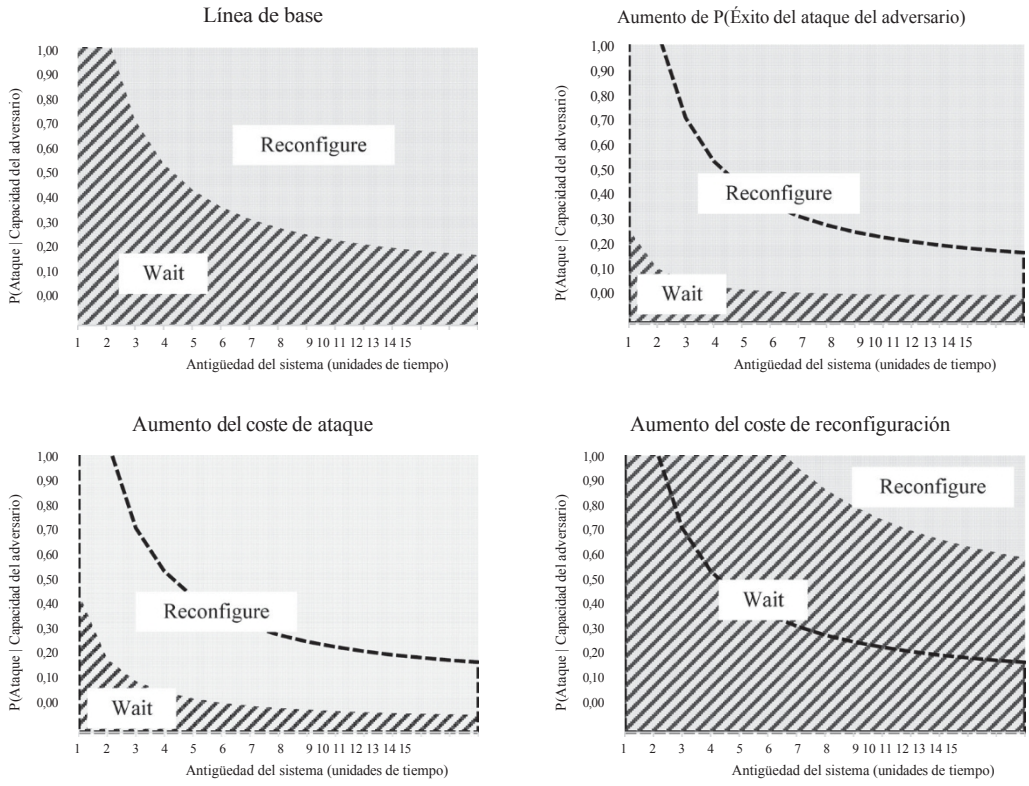


Fig. 11. Evolución del sistema a lo largo del tiempo y decisiones del defensor (la línea discontinua muestra una comparación de cada frontera de decisión con la línea de referencia).

Para tomar estas decisiones, el administrador del sistema debe estimar el coste de un ataque exitoso y de la reconfiguración del sistema, incluyendo la mano de obra y el tiempo de inactividad. A continuación, el modelo se utiliza para calcular la frontera que divide las dos opciones (adoptar una nueva configuración o esperar) en términos de probabilidad de un ataque en función de la antigüedad del sistema. En la Fig. 11 se muestran resultados ilustrativos basados en un escenario de decisión hipotético en el que asumimos los siguientes datos. La probabilidad de que un adversario desarrolle un nuevo exploit cibernético es de 0,10 por unidad de tiempo (por ejemplo, por mes), y la probabilidad de que decida utilizarlo en la siguiente unidad de tiempo, dado que es una opción, también es de 0,10. Un ataque exitoso le cuesta al operador del sistema 1.000 $ y reconfigurar el software para frustrar un ataque cuesta
200 $. La parte superior izquierda de la fig. 11 muestra los resultados de referencia. Las tres partes restantes ofrecen comparaciones entre la frontera de decisión de referencia (línea discontinua) y los casos en los que se modifican los valores de entrada: aumentando la probabilidad de éxito del exploit a 0,60, el coste del ataque a 4.000 $ y el coste de reconfiguración a
600 dólares.

La fig. 11 ilustra, por tanto, la naturaleza dinámica del sistema cibernético analizado. A medida que pasa el tiempo, cabe esperar que el adversario obtenga ventaja. El administrador del sistema puede evaluar la estrategia del adversario basándose en su valoración de las probabilidades de que este ataque una vez que encuentre una vulnerabilidad. A medida que pasa el tiempo, reconfigurar el sistema será preferible a esperar. Las instituciones que se enfrentan a adversarios con mayor capacidad técnica, como los actores estatales, querrán reconfigurar antes (parte superior derecha de la fig. 11), al igual que las instituciones que sufren mayores costes si se produce un ataque (parte inferior izquierda). Sin embargo, unos costes de reconfiguración más elevados retrasarán el momento óptimo para reconfigurar el sistema (parte inferior derecha).

7. CONCLUSIÓN: CUANTIFICACIÓN DEL RIESGO EN LA GESTIÓN DEL RIESGO CIBERNÉTICO Y EL USO DE LA PROBABILIDAD

Se destinan grandes cantidades de dinero a la gestión del riesgo cibernético, a menudo sin disponer de mucha información sobre la eficacia de las medidas adoptadas ni sobre las

prioridades entre ellas. Las empresas, los particulares y los países consideran que el riesgo cibernético es preocupante y, en algunos casos, aterrador. Las compañías de seguros, cuando deciden entrar en ese mercado, se ven en la difícil situación de tener que justificar los precios de las primas.

En este artículo hemos presentado varias formas de recopilar y utilizar la información disponible para cuantificar el riesgo cibernético al que se enfrenta un posible objetivo, reconociendo que la información relevante va más allá de las estadísticas históricas. Los tres casos ilustrativos descritos en este artículo proporcionaron ejemplos de apoyo a la toma de decisiones mediante la cuantificación del riesgo cibernético y los beneficios de reducción del riesgo de una gama de contramedidas, tales como el cifrado, la reducción del número de puntos de entrada o la modificación del software operativo. La elección depende entonces de la actitud ante el riesgo del responsable de la toma de decisiones. En este caso hemos asumido la neutralidad ante el riesgo, pero pueden introducirse otras actitudes ante el riesgo mediante otras funciones de utilidad y ciertos equivalentes.

En los últimos años se han logrado avances sustanciales en el desarrollo del análisis de riesgos cibernéticos, pasando de la convicción arraigada de que no había forma de cuantificar dichos riesgos a preguntarse cómo se puede mejorar esa cuantificación. Recopilar estadísticas de incidentes y sus consecuencias, y luego compartir los datos en los foros adecuados para proteger a las organizaciones cuando sea necesario, es un buen punto de partida. La siguiente tarea consiste en analizar y ampliar estas bases de datos para abordar el riesgo de ataques que aún no se han producido.

En muchos casos, el primer paso básico consiste en comprender qué es lo que hay que proteger, dónde se encuentra y cuál es la estructura de la red interna de información que podría verse comprometida. Desde la perspectiva del defensor, ese análisis debe incluir las incertidumbres y la dinámica de los ciberataques, teniendo en cuenta la evolución de los conocimientos, los medios y las intenciones de los adversarios.

Por lo tanto, nuestras principales recomendaciones para una organización que pueda ser objetivo incluyen:

- Conozca su sistema y decida qué es lo que hay que proteger con prioridad.
- Recopile datos sobre los ataques que se han producido;
  acceda a esa información y actualícela periódicamente, y extrapole para considerar posibles ataques que quizá aún no se hayan producido, pero contra los que es necesario protegerse.
- Identifique el abanico de contramedidas que
  que tenga sentido teniendo en cuenta tu estructura y tu misión.
- Analice los datos y la información adicional pertinente para decidir qué conjunto de contramedidas
  deben adoptarse teniendo en cuenta los límites presupuestarios, las pérdidas potenciales y los beneficios de protección.

En cada uno de los tres casos ilustrativos aquí considerados, identificamos un óptimo que refleja los presupuestos y las compensaciones. Para la organización que nos dio acceso a sus estadísticas de ataques, se trata de una elección de contramedidas básicas. En el caso de las redes inteligentes, se trata de un nivel óptimo de conectividad. En cuanto a la gestión del software de una infraestructura, se trata de una frecuencia de actualización o sustitución. Una vez más, los detalles de un análisis de riesgos cibernéticos dependerán de las características de los sistemas específicos y de las organizaciones gestoras. Hemos demostrado aquí que estos óptimos existen y pueden cuantificarse.

AGRADECIMIENTOS

M.-Elisabeth Pate´-Cornell es profesora de la cátedra Burt y Dee-dee McMurtry en la Escuela de Ingeniería de Stanford. Esta investigación (incluida la beca de investigación de Marshall Kuypers) fue financiada en parte por una subvención de la NASA/JPL y por una beca de posgrado Burt y Deedee McMurtry. La investigación de Philip Keller se llevó a cabo con
el apoyo del Gobierno federal de EE. UU. en el marco de una beca NDSEG. Matthew Smith es oficial de Investigación Operativa y Análisis de Sistemas en el Ejército de EE. UU., por lo que cuenta con financiación del Departamento de Defensa. Los tres coautores eran doctorandos del Grupo de Investigación sobre Riesgos en Ingeniería del Departamento de Ciencias de la Gestión e Ingeniería de Stanford en el momento de redactar este artículo. Las declaraciones contenidas en este artículo no representan las opiniones del Gobierno de EE. UU. ni de la Universidad de Stanford.

REFERENCIAS

1. Storm D. Los atacantes piratearon el Departamento de Energía 159 veces en 4 años. Análisis de noticias, Computer World, 14 de septiembre de 2015.
2. Peterson A. La OPM afirma que se robaron 5,6 millones de huellas dactilares en un ciberataque, cinco veces más de lo que se pensaba. Washington Post, 2015;
3. North American Electric Reliability Corporation. Ciberseguridad: Categorización de sistemas cibernéticos BES. Atlanta, GA, 2014.
4. Departamento de Seguridad Nacional. Práctica recomendada: Mejora de la ciberseguridad de los sistemas de control industrial mediante estrategias de defensa en profundidad. Washington, D.C., 2009.
5. Kuypers MA, Maillart T, Pate´-cornell E. Análisis empírico de los incidentes de ciberseguridad en una gran organización. Documento de trabajo, Palo Alto, CA, 2016. Disponible en: cisac.fsi.stanford.edu.
6. Kuypers MA. El riesgo en los sistemas cibernéticos. Tesis doctoral, Departamento de Ciencias de la Gestión e Ingeniería, Universidad de Stanford, marzo de 2017.
7. Smith M, Pate´-Cornell E. Análisis de riesgos cibernéticos para una red inteligente: ¿Qué grado de inteligencia es suficiente? Un enfoque de bandido de múltiples brazos.

Págs. 37-56 en Actas de la 2.ª Conferencia de Investigación sobre Ciberseguridad de Singapur, 2017.
8. Parnell GS, Butler RE, Wichmann SJ, Tedeschi M, Merritt D. Análisis de la inversión de la Fuerza Aérea en el ciberespacio. Análisis de Decisiones, 2015; 12(2):81–95.
9. Rao NSV, Poole SW, Ma CYT, He F, Zhuang J, Yau DKY. Defensa de las infraestructuras cibernéticas frente a ataques ciberfísicos mediante modelos de teoría de juegos. Análisis de Riesgos, 2015; 1–17.
10. Director de Sistemas de Información del Departamento de Defensa. Instrucción del Departamento de Defensa: Ciberseguridad 8500.01. Washington, D.C., marzo de 2014.
11. Stoddard M, Bodeau D, Carlson R, Glantz C, Haimes Y, Lian C, et al. Métricas de seguridad de los sistemas de control de procesos: estado actual de la práctica. Informe de investigación del Instituto I3P para la Protección de la Infraestructura de la Información, 2005, vol. 1.
12. Corporación Norteamericana de Fiabilidad Eléctrica. Directrices de seguridad para el sector eléctrico. Atlanta, GA, 2015.
13. The MITRE Corporation. Vulnerabilidades y exposiciones comunes. National Cybersecurity FFRDC, 2017. Disponible en: https://cve.mitre.org/.
14. US ICS-CERT. Ciberataque contra la infraestructura crítica de Ucrania, 2016. Disponible en: https://ics-cert.us-cert.gov/alerts/IR-ALERT-H-16-056-01.
15. Lee R, Assante MJ, Conway T. Análisis del ciberataque a la red eléctrica ucraniana. SANS Industrial Control Systems. Informe E-ISAC, Washington, DC, 2016.
16. Schneider KP, Fuller JC, Tuffner FK, Singh R. Evaluación de la reducción de tensión por motivos de conservación (CVR) a nivel nacional. Laboratorio Nacional del Noroeste del Pacífico, 2010; julio de 2010:114.
17. Morgan M, Apt J, Lave L, Ilic M, Sirbu M, Peha J. Los múltiples significados de «red inteligente». Departamento de Ingeniería y Políticas Públicas, Muestra de Investigación de la Universidad Carnegie Mellon, 2009. Disponible en: http://repository.cmu.edu/cgi/viewcontent.cgi?article=1026&context=epp, consultado el 29 de octubre de 2014.
18. Lee A. Escenarios de fallo del sector eléctrico y análisis de impacto. Grupo de Trabajo Técnico de la Organización Nacional de Recursos de Ciberseguridad del Sector Eléctrico (NESCOR), vol. 1, 2013.
19. Larrosa C, Kaneshiro L, Zhao J, Elisabeth Pate-Cornell M. Efecto del clima espacial severo en los fallos en cascada de la red eléctrica : un modelo ilustrativo y sus implicaciones políticas. 11.ª Conferencia Internacional sobre Evaluación y Gestión Probabilística de la Seguridad y Conferencia Anual Europea sobre Seguridad y Fiabilidad 2012, PSAM11 ESREL 2012, 2012; 7:5253–5262.
20. Deng R, Yang Z, Chow M-Y, Chen J. Estudio sobre la respuesta a la demanda en las redes inteligentes: modelos y enfoques matemáticos. IEEE Transactions on Industrial Informatics, 2015; 11(3): 570–582.
21. Administración de Información Energética de EE. UU. Archivos de datos de la encuesta detallada sobre electricidad, 2015. Disponible en: https://www.eia.gov/electricity/data/eia861/.
22. Kwag HG, Kim JO. Programación combinada óptima de la generación y la respuesta a la demanda con restricciones de recursos de demanda. Applied Energy, Elsevier Ltd, 2012; 96:161–170.
23. Ponemon Institute. Estudio sobre el coste de las violaciones de datos: análisis global. Informe de investigación del Ponemon Institute, 2016.
24. Instituto Nacional de Estándares y Tecnología de EE. UU. Base de datos nacional de vulnerabilidades. Disponible en: https://nvd.nist.gov/home.cfm, consultado el 3 de abril de 2017.
25. Bilge L, Dumitras T. Investigación de ataques de día cero. Login, 2013; 38(4):6–13.
26. Clark S, Frei S, Blaze M, Smith J. La familiaridad engendra desprecio: el efecto luna de miel y el papel del código heredado en las vulnerabilidades de día cero. Págs. 251–260 en Actas de la Conferencia Anual sobre Aplicaciones de Seguridad Informática (ACSAC), Orlando, FL, 2010.
27. Nappa A, Johnson R, Bilge L, Caballero J, Dumitras¸ T. El ataque de los clones: un estudio del impacto del código compartido en la aplicación de parches de vulnerabilidades. Actas del Simposio IEEE sobre Seguridad y Privacidad, 2015; julio de 2015:692–708.
28. Mell P, Scarfone K, Romanosky S. Una guía completa del Sistema Común de Puntuación de Vulnerabilidades, versión 2.0. Págs. 1–23 en FIRSTForum de Equipos de Respuesta a Incidentes y Seguridad, 2007.
29. Cavusoglu, H., Mishra, B. y Raghunathan, S. «El efecto de los anuncios de violaciones de la seguridad en Internet sobre el valor de mercado: reacciones de los mercados de capitales ante las empresas afectadas y los desarrolladores de soluciones de seguridad en Internet». International Journal of Electronic Commerce, 2004; 9(1):69–104.